

# Swatting Flies w/ Sledgehammers: Broken TPRM Programs and How to Fix Them

RVAssec 15 // June 10, 2026



# Hi, I'm Brian 🖐️

(and these views are my own and do not represent those of my employer)



father, i crave  
violence



the horrors persist but so do i





BLOG

# An open letter to third-party suppliers

By Patrick Opet, Chief Information Security Officer

April 26, 2025

CYBERSECURITY

LEADERSHIP STORIES

INSIGHTS AND DISCUSSIONS

SHARE



The modern 'software as a service' (SaaS) delivery model is quietly enabling cyber attackers and – as its adoption grows – is creating a substantial vulnerability that is weakening the global economic system.

- Software providers must prioritize security over rushing features. Comprehensive security should be built in or enabled by default.
- We must modernize security architecture to optimize SaaS integration and minimize risk.
- Security practitioners must work collaboratively to prevent the abuse of interconnected systems.



Third-Party Risk Management is about  
*reasonable assurance* - not perfection.

*Transparency* is the present and  
future of TPRM.

Over-engineered approaches to TPRM *steal resources from other security domains* and don't make anything more secure.

Independent third-party audits, certifications, and industry standards *should be preferred* over custom questionnaires.

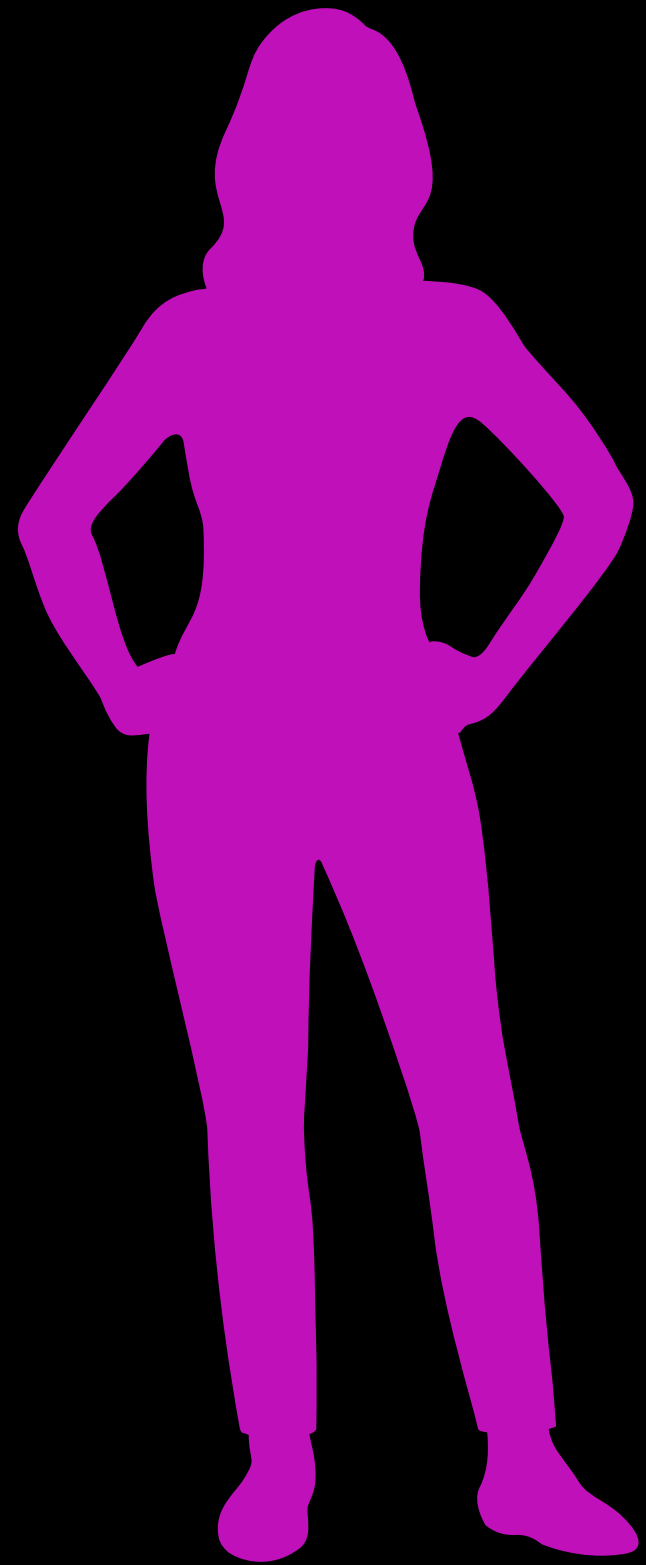
It's not about security. It's about *trust*.



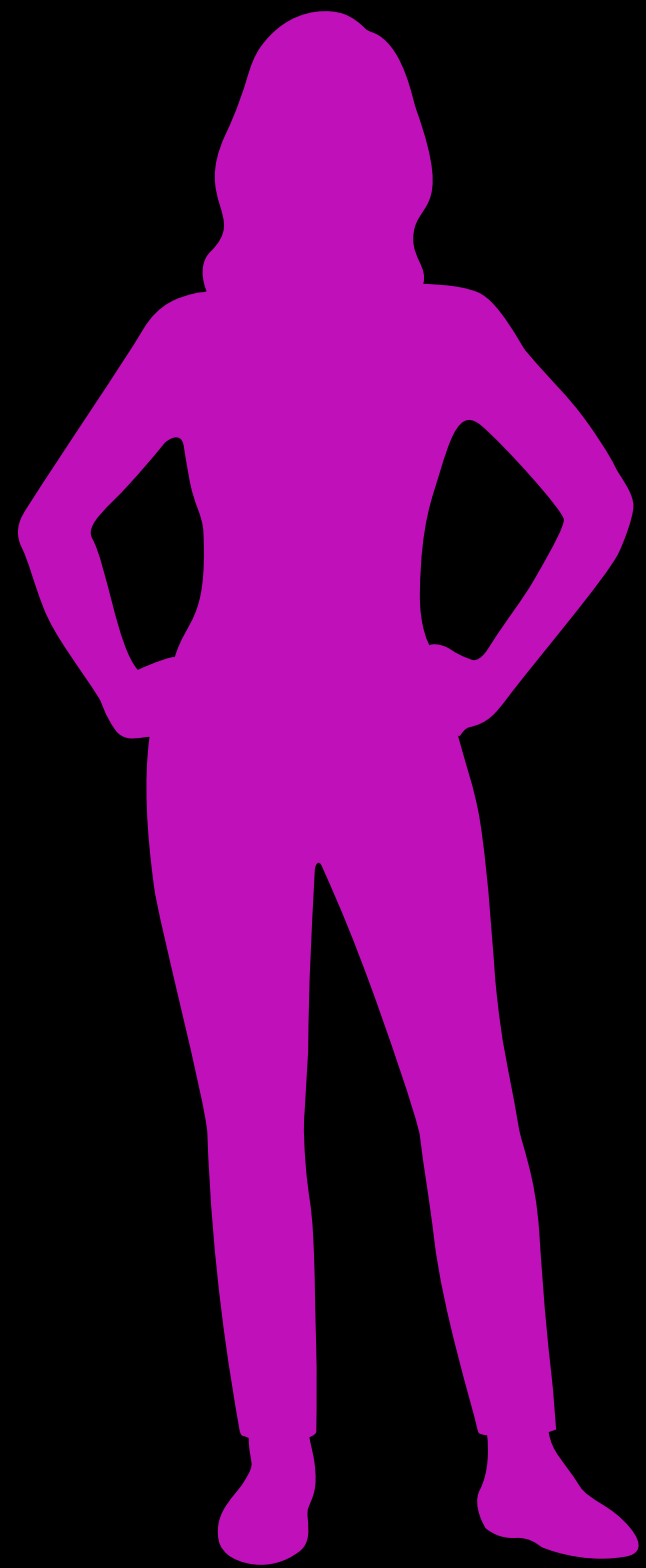
# Child Care

# Child Care

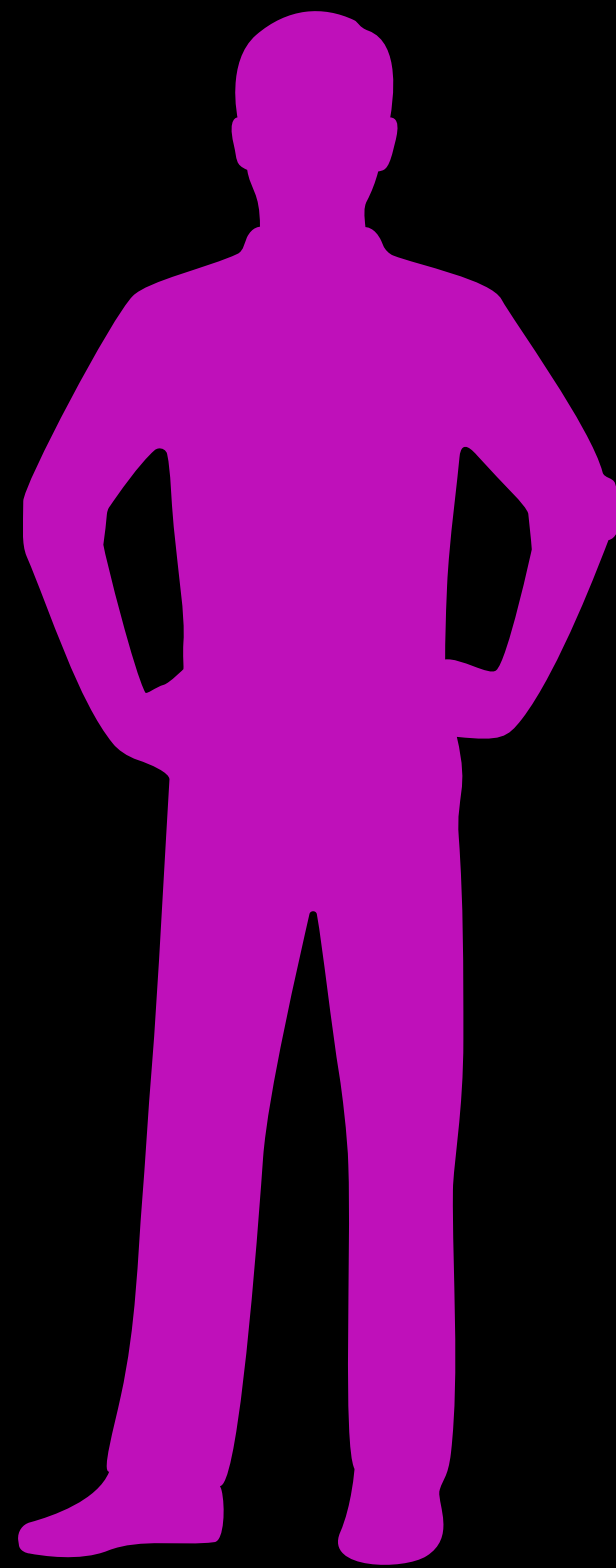
(But more on that later)



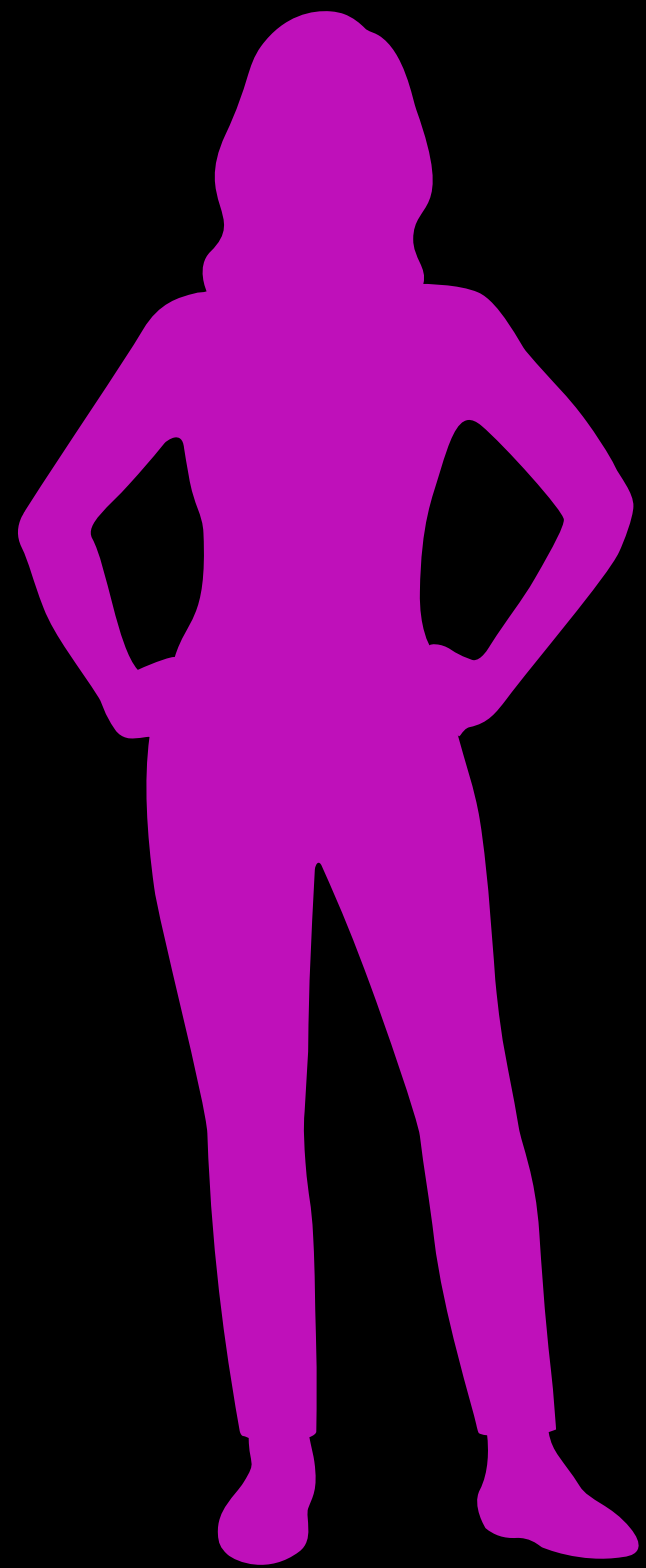
Buyer



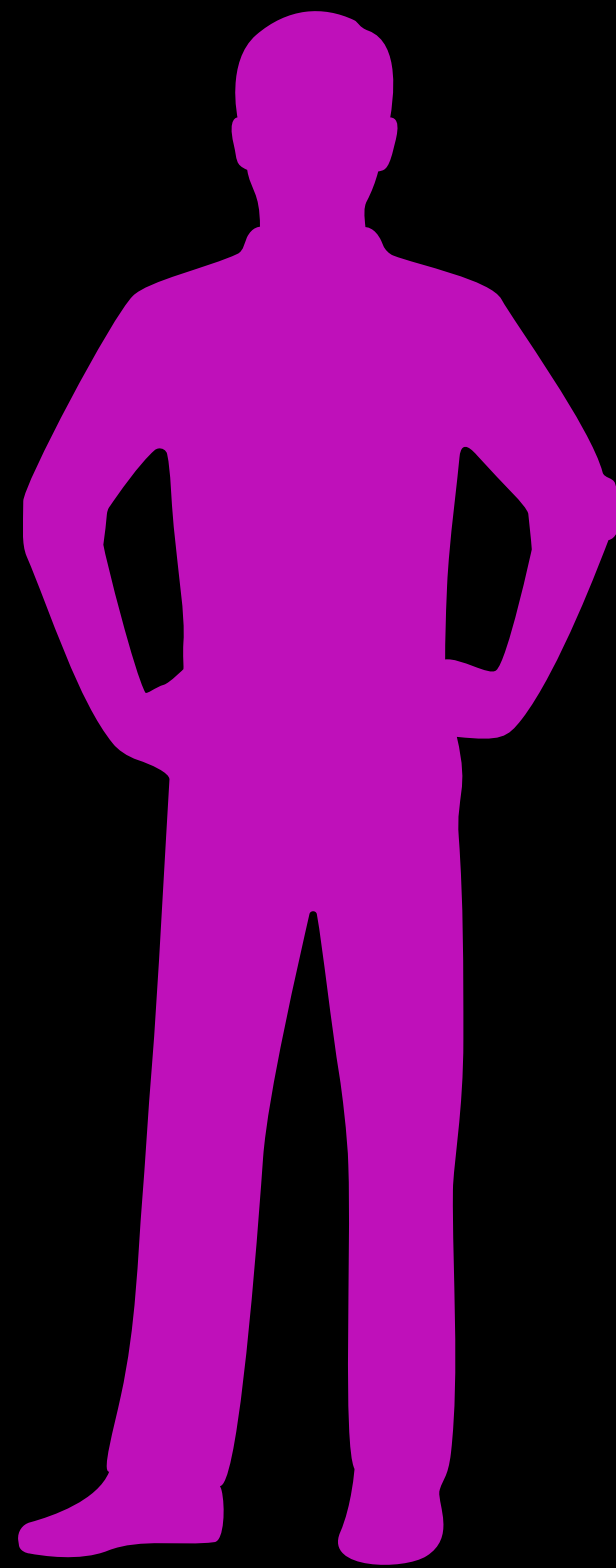
Buyer



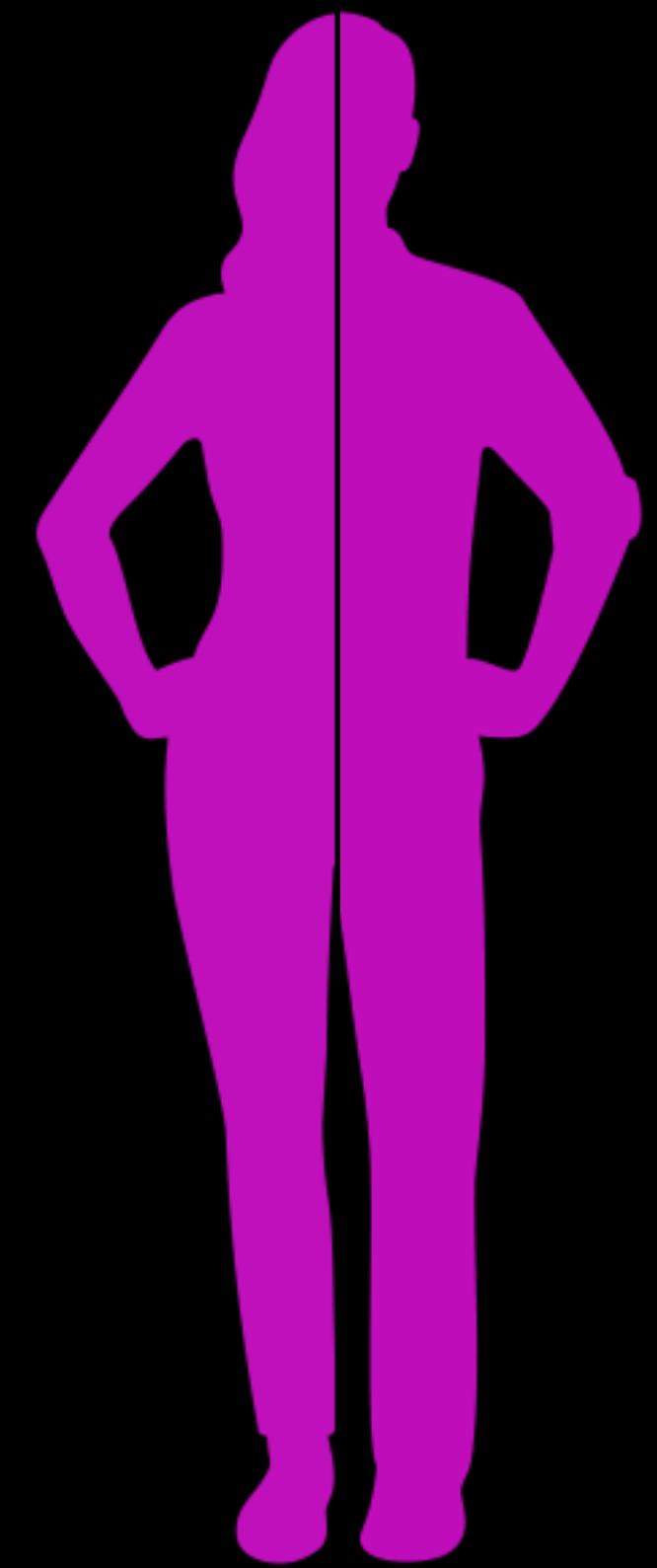
Seller



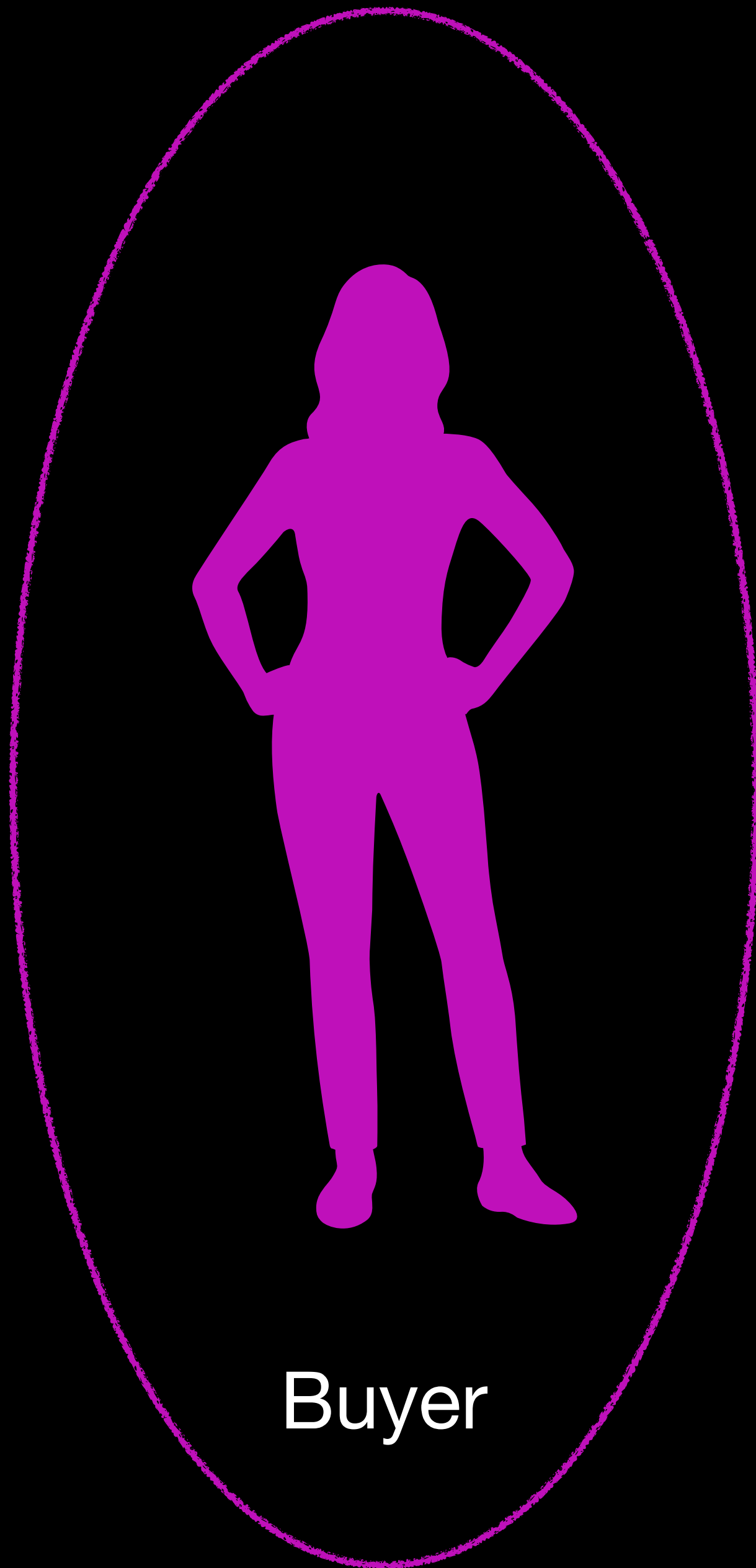
Buyer



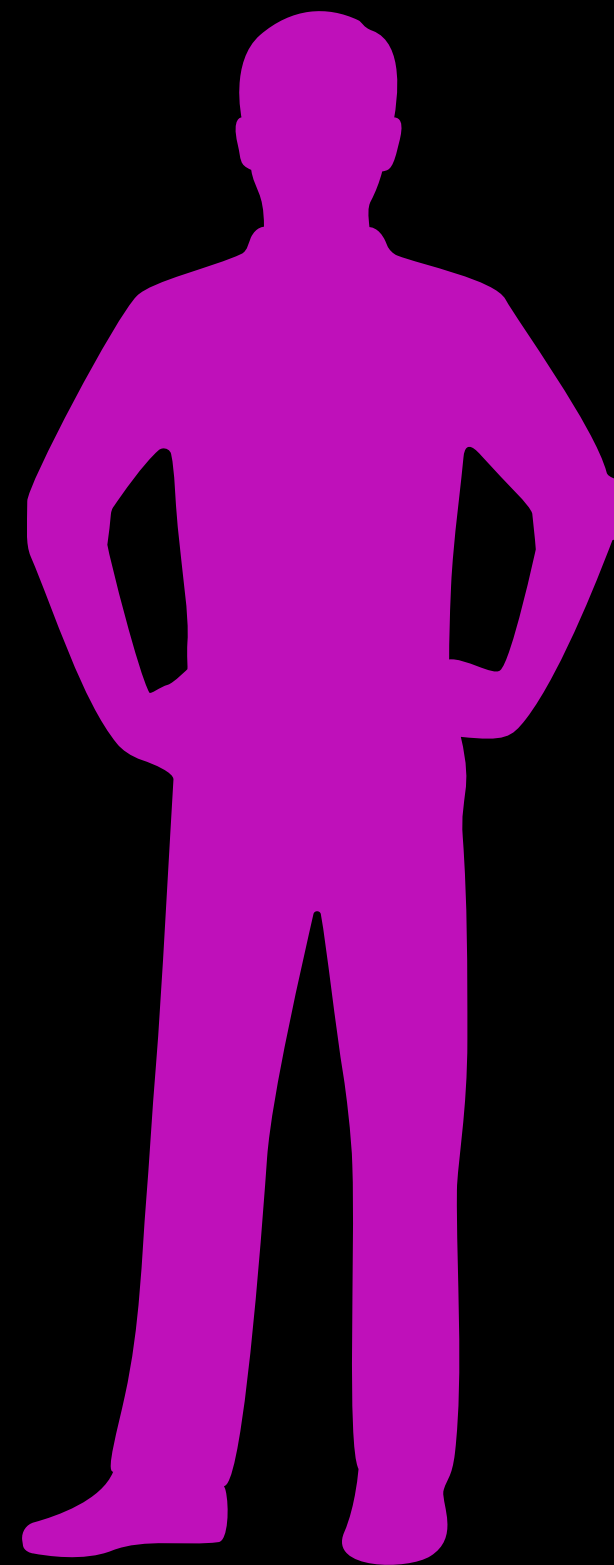
Seller



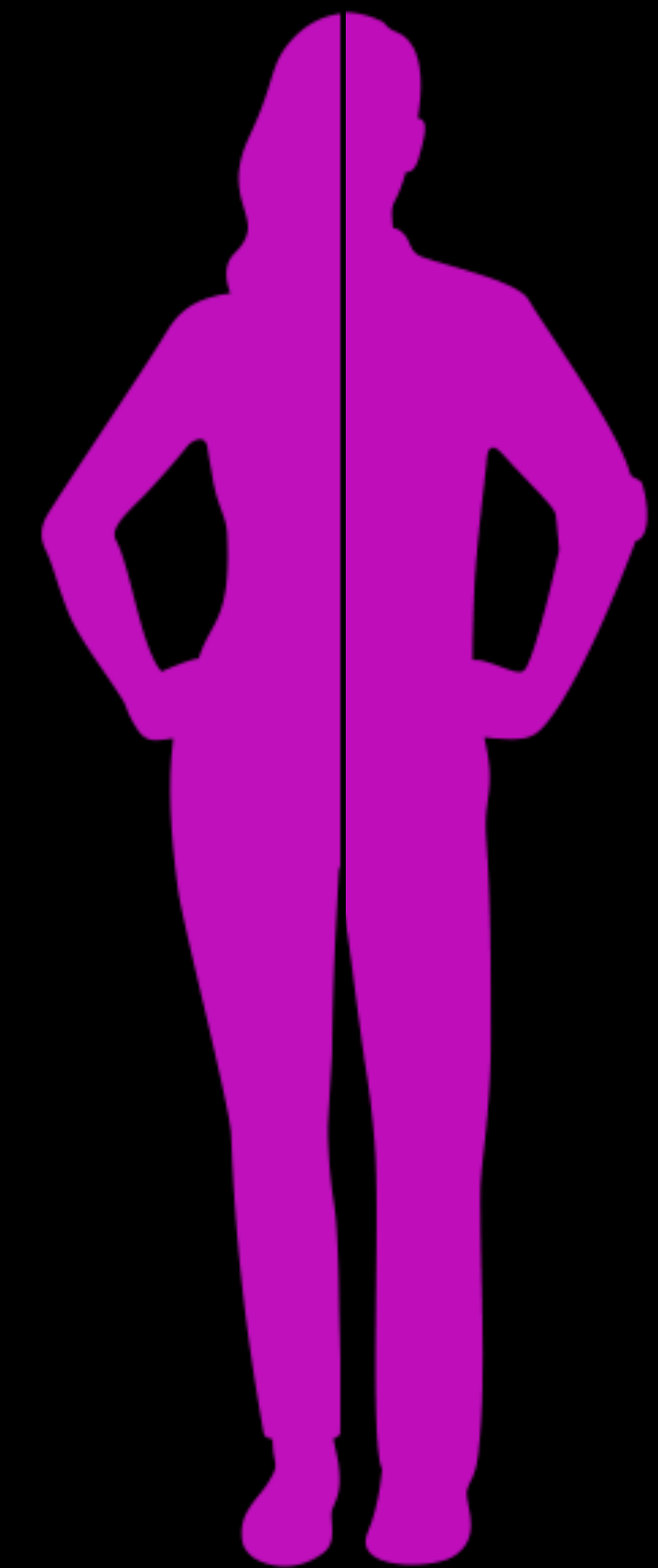
Orgs that  
buy and sell



Buyer



Seller



Orgs that  
buy and sell

1. Origins of TPRM
2. Current methods of TPRM
3. Next generation TPRM
4. Summary and Call to Action

# Working definition of TPRM

- Third-party: any entity that is external to our organization
  - Supplier, vendor, customer, investor, etc.
- These relationships are essential for our organizations but introduce risk
- TPRM identifies, assesses, and manages risks associated with these third-parties
- Security risk is just one area of risk that can be introduced by a third-party and it is the one we'll focus on for today.

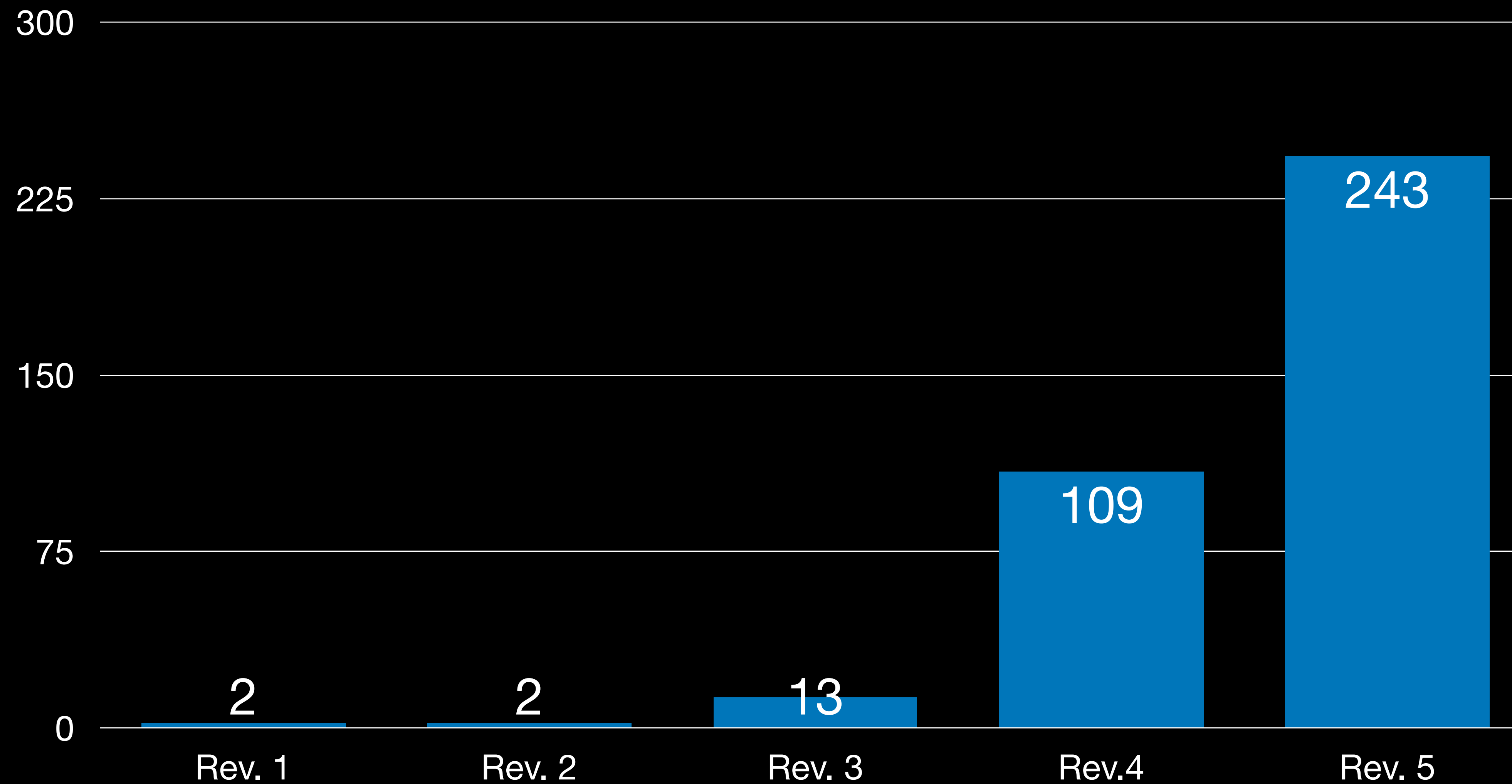
# Goals of TPRM

- Make security risk aware decisions regarding third-parties (procurement, integrations, M&A).
- Advise the business on risks associated with third-parties; influence buying decisions, contract language, and compensating controls.
- Maintain an inventory of all third-parties, the services they provide, internal/external PoC, and their risk profile.

**BACK IN MY DAY**

**VENDOR ASSESSMENTS  
WERE A PROCUREMENT FUNCTION**

# Mentions of “Supply Chain” in NIST 800-53



# Specific Controls and Requirements

## NIST 800-53 v5, Supply Chain Risk Management (SR)

SR-6:

“Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide.”

“The reviews consider documented processes, documented controls, all-source intelligence, and publicly available information related to the supplier or contractor. Organizations can use open-source information to monitor for indications of stolen information, poor development and quality control practices, information spillage, or counterfeits”

# Specific Controls and Requirements

## CIS Controls v8.1

1. Establish and Maintain an Inventory of Service Providers
2. Establish and Maintain a Service Provider Management Policy
3. Classify Service Providers
4. Ensure Service Provider Contracts Include Security Requirements
5. Assess Service Providers
6. Monitor Service Providers
7. Securely Decommission Service Providers

“While reviewing the security of third-parties has been a task performed for decades, there is not a universal standard for assessing security; and, many service providers are being audited by their customers multiple times a month, causing impacts to their own productivity.”

CIS Controls v8.1 (pg. 70)

“The registrant has policies and procedures to oversee and identify the cybersecurity risks associated with its use of any third-party service provider (including, but not limited to, those providers that have access to the registrant’s customer and employee data), including whether and how cybersecurity considerations affect the selection and oversight of these providers and contractual and other mechanisms the company uses to mitigate cybersecurity risks related to these providers.”

SEC Proposed Rule (33-11038)

**What are we trying to achieve  
and are we achieving it?**

**Can we do a better job than an auditor  
with hundreds of hours of access to  
people, documentation, and systems?**

**Who or what drives the amount of time, effort, and resources that goes into our current TPRM processes?**

1. Origins of TPRM
2. Current methods of TPRM
3. Next generation TPRM
4. Summary and Call to Action

# Current Methods of TPRM

- Independent audits, assessments, and certifications.
- Cybersecurity Risk Rating Services
- Industry standard questionnaires
- Custom Questionnaires

# Independent audits, assessments, and certifications

- SOC 2 (Type I, Type II)
- ISO/IEC 27001:2022
- HITRUST r2
- PCI-DSS ROC or AOC
- CSA Star Level 2
- FedRAMP (Moderate or High)
- CMMC Level 2 or 3



# What do these have in common?

- Assessor must be vetted by a governing body
- Standard has been time-tested and revised over time to meet new requirements and remove antiquated controls
- Requires rigor and continuous performance of good security practices

OK...but

# OK but...SOC2 audits are flawed

Delve went to Hawaii for our sins

- Critique of SOC2 audits are fair.
- There are SOC2 puppy mills, there are “easy A” SOC2 auditors.
- Many new services claiming SOC2 “compliance” in two weeks.
- A legit SOC2 report - even a clean one - isn’t indicative of future performance or an exceptional security program.





Secureframe

<https://secureframe.com> › frameworks › soc-2



## SOC 2 Compliance in Weeks, Not Months

Get **SOC 2** ready in **weeks**, not months. Secureframe automates and streamlines the SOC 2 process at every step so you can get audit ready quickly and easily. [Read more](#)

## Sponsored results

Oneleet

<https://www.oneleet.com> › soc\_2



## Backed by \$33M Series A - SOC 2 Without Checklists

Book a demo to see how teams get **SOC 2** audit-ready without compliance chaos. 5-star rated **SOC 2** compliance platform backed by a \$33M Series A. Book Demo Now. Faster Time to Audit. End-to-End Compliance. Audit-Ready Faster.

10K+ visits in past month

### View Pricing Plans

Transparent pricing options Flexible plans by company size



Sprinto

<https://www.sprinto.com>



## Get SOC 2 Certified in Weeks - Budget Friendly SOC 2 in Days

Prove **SOC 2** readiness in **weeks**. Fix gaps before audits. Simplify **SOC 2** certification with automation & dashboards. 2026 G2 Leader.

[Get SOC 2 in Weeks, Not Months](#) · [Clear Pricing](#). [No Hidden Costs](#) · [Calculate Compliance Cost](#)

100K+ visits in past month



polara

## Polara Labs

SOC 2 Compliant. One Week. One Payment.

Security and Investigations · 44 followers · 2-10 employees

+ Follow

✉ Message



Home

About

Posts

Jobs

People

Delve - Fake Compliance as a

Ask Gemini

deepdelver.substack.com/p/delve-fake-compliance-as-a-service

☆

8

B

DeepDelver

🔍💬🔔

Subscribe

DEEDELVER

MAR 18, 2026

♡ 603

💬 53

🔄 79

Share

⋮

The version that arrived in your mailbox is truncated. [Visit the full article here to view the rest.](#)

How ~~Delve~~ managed to scam the below companies and hundreds others into believing they are compliant

IN-COR-TA

sully.ai

Lovable

Cluely

Flow

Slash

DUOS  
EDGE AI

Browser Use

BLAND.AI

HockeyStack

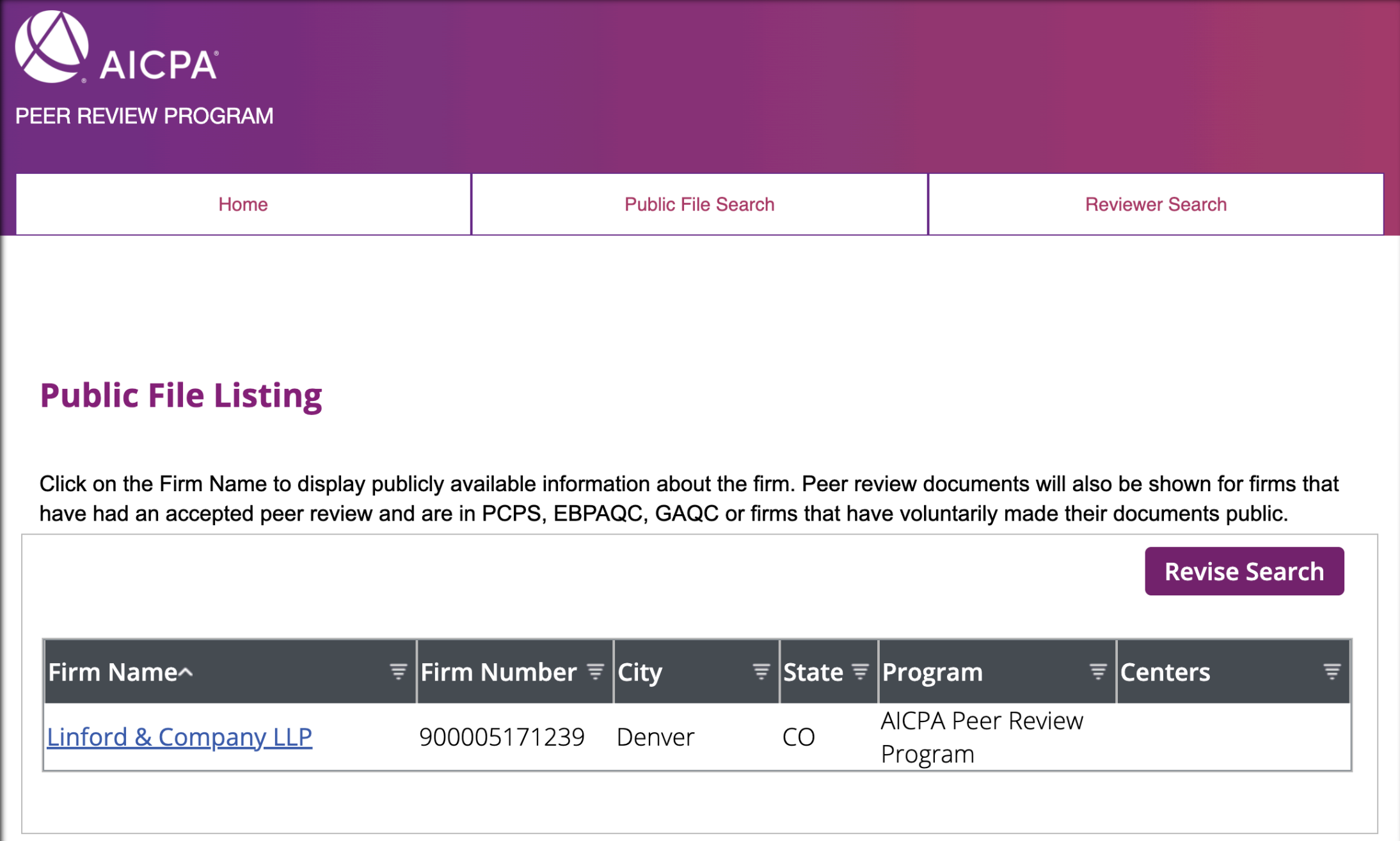
Knowtex

Source: <https://deepdelver.substack.com/p/delve-fake-compliance-as-a-service>

# Rooting out shady SOC2 reports

Delve went to Hawaii for our sins

- Who conducted the audit? Are they peer reviewed?
  - [https://peerreview.aicpa.org/public\\_file\\_search.html](https://peerreview.aicpa.org/public_file_search.html)
- How long has the company been in business? Is it reasonable that they would have a SOC2 given their age and maturity?



The screenshot shows the AICPA Peer Review Program website. The header is purple with the AICPA logo and 'PEER REVIEW PROGRAM' text. Below the header is a navigation bar with three links: 'Home', 'Public File Search', and 'Reviewer Search'. The main content area is white and titled 'Public File Listing'. It includes a paragraph explaining that clicking on a firm name displays publicly available information and that peer review documents are shown for firms in PCPS, EBPAQC, GAQC, or those that have voluntarily made their documents public. Below this is a table with a 'Revise Search' button in the top right corner. The table has six columns: Firm Name, Firm Number, City, State, Program, and Centers. A single row is visible for 'Linford & Company LLP'.

| Firm Name^                                | Firm Number  | City   | State | Program                   | Centers |
|-------------------------------------------|--------------|--------|-------|---------------------------|---------|
| <a href="#">Linford &amp; Company LLP</a> | 900005171239 | Denver | CO    | AICPA Peer Review Program |         |

# Cybersecurity Risk Rating (CRR) Services

- BitSight, Security Scorecard, Black Kite, UpGuard, RiskRecon, Panorays.
- Use open-source intelligence, Internet scans, and proprietary signals to give vendors a risk score.
- Customers pay to use the platform, third-parties can monitor their profile (generally for free), customers can sponsor third-parties.

# Cybersecurity Risk Rating (CRR) Services

## Pros

---

- It's easy (low time to value) - just buy something and you have data about prospective third-parties.
- OSINT is already done for you.
- Monitor third-parties and yourself.

## Cons

---

- False positives.
- Subjective or proprietary ratings/grades.
- Expensive, especially when you pay for every third-party.
- Unclear where data is being sourced (if you're the third-party)

# Industry Standard Questionnaires

- Consensus Assessments Initiative Questionnaire (CAIQ)
  - V4 is 261 questions
- Higher Education Community Vendor Assessment Toolkit (HECVAT)
- Standardized Information Gathering (SIG) 💰
  - Core (853) vs. Lite (135)
  - Full SIG is 2909 questions
- Vendor Security Assessment Questionnaires (VSAQ) by Google
  - <https://vsaq-demo.withgoogle.com/>

# Industry Standard Questionnaires

## Pros

---

- Fill out once, use everywhere.
- Time tested, proven to be useful over time.
- Well-known and accepted.

## Cons

---

- Time consuming to complete and keep current.
- Does not necessarily rule out a custom questionnaire.

# Custom Questionnaires

- You have questions, I get it. I have questions too.
- What questions are essential vs. nice to have?
- What questions can be replaced by artifacts?
- How many doors are you opening?

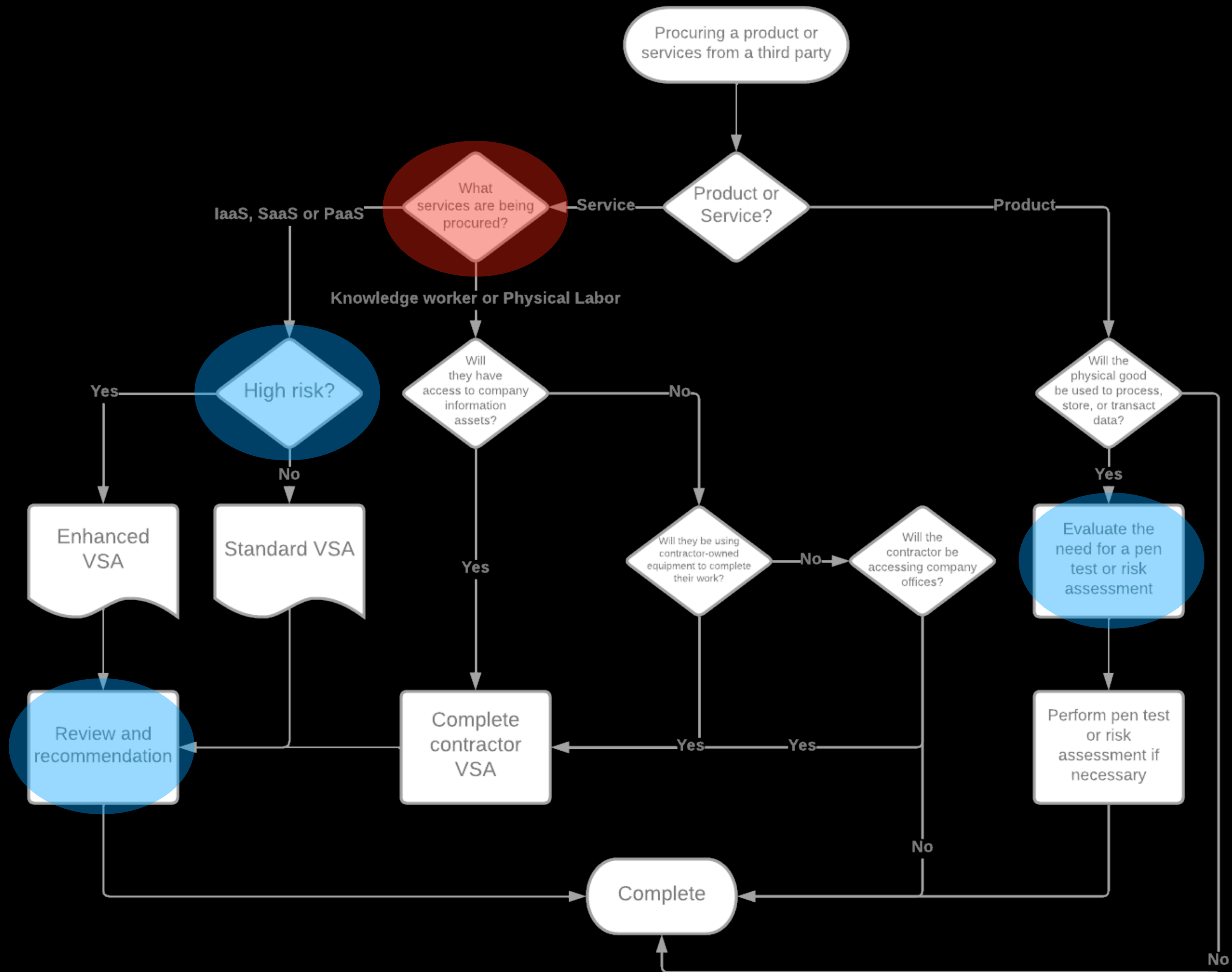
1. Origins of TPRM
2. Current methods of TPRM
3. Next generation TPRM
4. Summary and Call to Action

What *could* good look like?

Try *easier.*

# What could good look like?

1. Know what you're buying and have a standard approach to evaluating the risk of that vendor/service/application.



# What can we learn from due diligence processes?

- Full transparency
- Limited time to assess
- Not an audit
- Understand ownership and points of contact
- Security can (but typically won't) kill a deal



# What could good look like?

1. Know what you're buying and have a standard approach to evaluating the risk of that vendor/service/application.
2. Does the vendor have a security team? Who are they, how would you contact them, and how quickly can you expect to hear back from them?



⌘ K

## Trust at Asana



This Trust Center provides you with resources demonstrating Asana's continuous commitment to protecting customer data. Below you'll find information about Asana's trust practices including additional information related to security, privacy, AI, and general infrastructure documentation. We prioritize security in our product strategy and build our platform using best practices for highly available, scalable, and secure cloud applications. We regularly monitor and assess our program to ensure it meets or exceeds compliance and regulatory requirements.

Report a vulnerability at: [security@asana.com](mailto:security@asana.com)

Asana's security and privacy programs are led by industry veterans with decades of experience:

**Sean Cassidy:** Head of Security

**Whitney Merrill:** Head of Global Privacy & Data Protection Officer (DPO)

## Compliance



✓ CCPA



✓ CSA STAR



✓ DORA



✓ EU-US DPF



✓ FERPA



✓ GDPR



✓ GLBA



✓ HIPAA

✓ ISO/IEC  
27001✓ ISO/IEC  
27001 SoA✓ ISO/IEC  
27017:2015✓ ISO/IEC  
27018:2019✓ ISO/IEC  
27701✓ SOC 2 Type  
2

✓ SOC 3

✓ SOC 2 Type  
1

✓ TX-RAMP



✓ VPAT



✓ NIS 2

# What could good look like?

1. Know what you're buying and have a standard approach to evaluating the risk of that vendor/service/application.
2. Does the vendor have a security team? Who are they, how would you contact them, and how quickly can you expect to hear back from them?
3. Examine documentation that matters: SOC2 reports, ISO certification(s), pen test reports, SBOM, remediation SLAs or responsible disclosure policies.

What is the *minimum* amount of documentation that I need to assess a third-party?



Source: <https://www.veranda.com/travel/g28402412/best-libraries-in-the-world/>

VS.

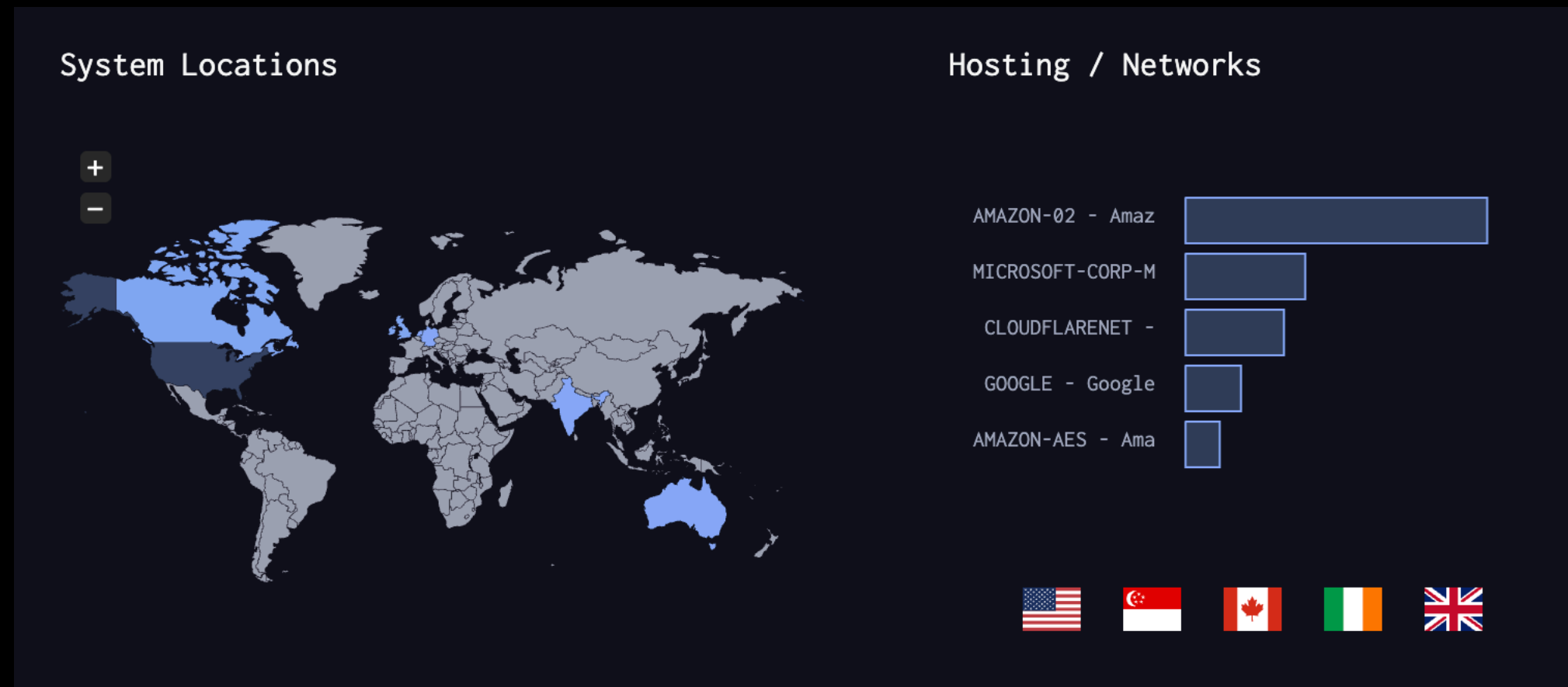


Source: <https://www.wildernesscollege.com/images/xsurvival-gear-list-pic-1.jpg.pagespeed.ic.xS84BXN-IQ.webp>

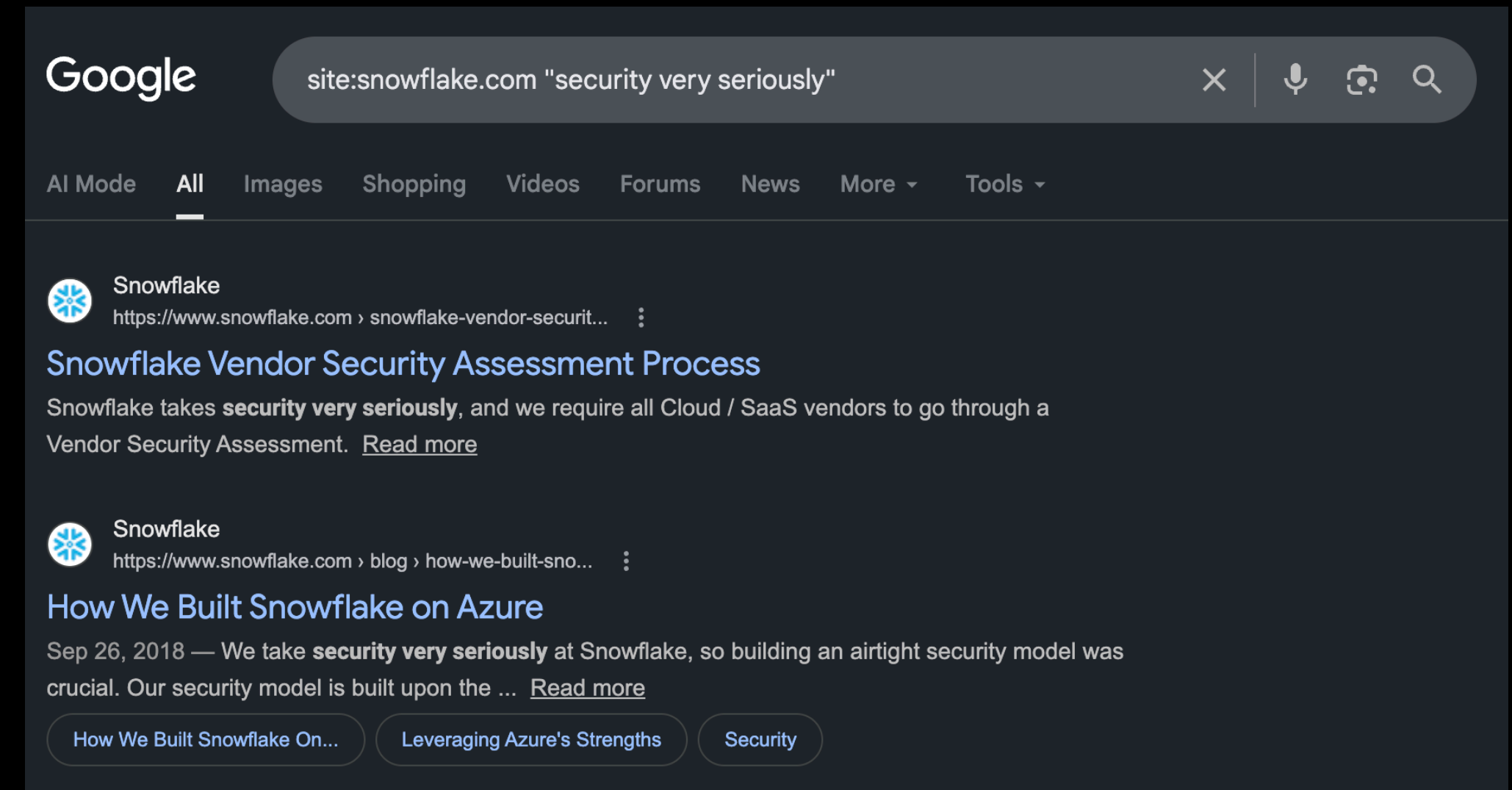
# What could good look like?

1. Know what you're buying and have a standard approach to evaluating the risk of that vendor/service/application.
2. Does the vendor have a security team? Who are they, how would you contact them, and how quickly can you expect to hear back from them?
3. Examine documentation that matters: SOC2 reports, ISO certification(s), pen test reports, SBOM, remediation SLAs or responsible disclosure policies.
4. Evaluate their online presence (OSINT, baby).

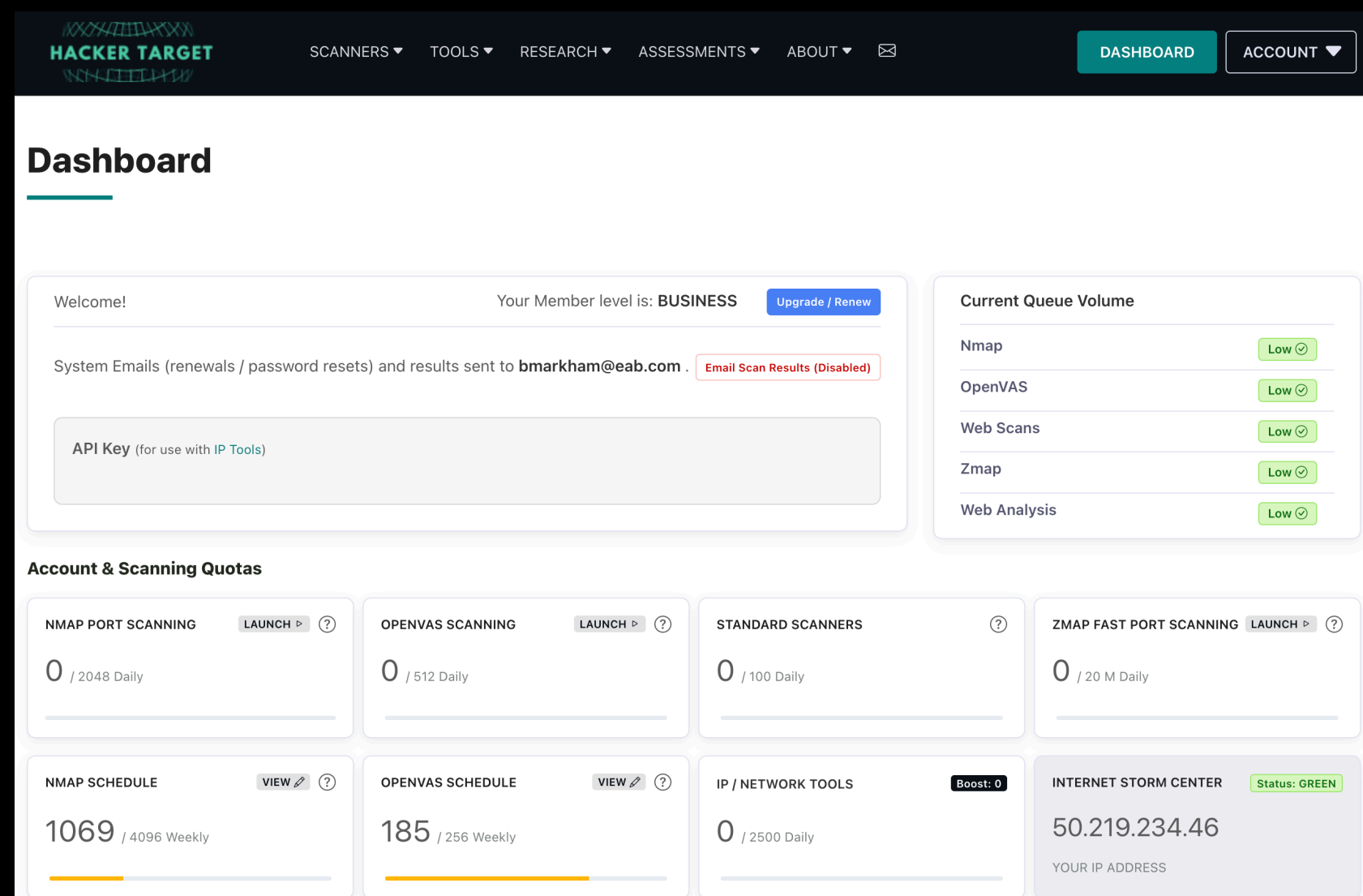
# DNS Dumpster



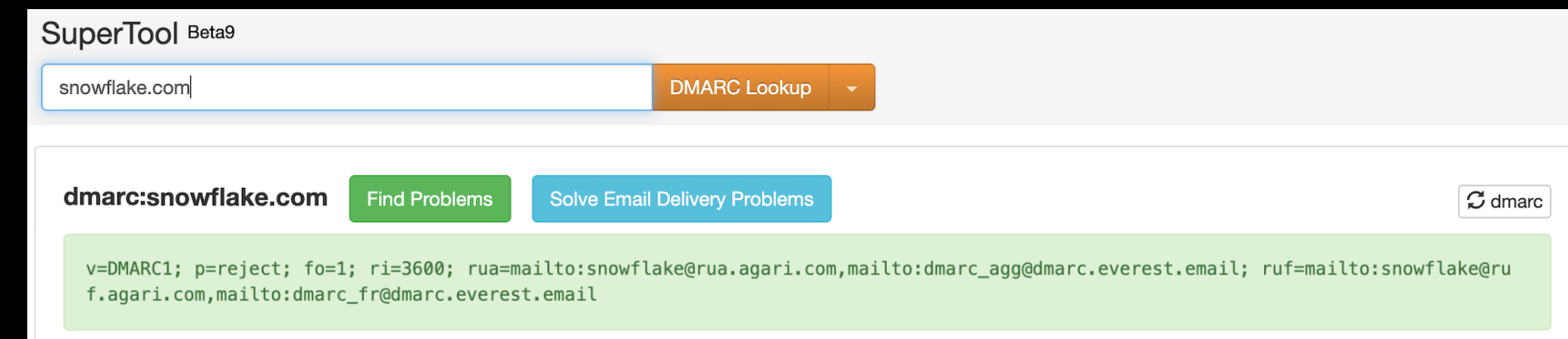
# Google.com



# Hacker Target



# MX Toolbox



# What could good look like?

1. Know what you're buying and have a standard approach to evaluating the risk of that vendor/service/application.
2. Does the vendor have a security team? Who are they, how would you contact them, and how quickly can you expect to hear back from them?
3. Examine documentation that matters: SOC2 reports, ISO certification(s), pen test reports, SBOM, remediation SLAs or responsible disclosure policies.
4. Evaluate their online presence (OSINT, baby).
5. Allow risk to sit with the business owner.



- (+) [REDACTED] has a trust center [REDACTED] which is a positive sign that they have a deliberate approach to security and recognize that their customers value security.
- (+) [REDACTED] has undergone a SOC2, Type II audit and we will have the opportunity to review this in more detail once you sign on as a TEAM user.
- (+) [REDACTED] has documented a selection of key controls in their trust center which, upon review, appear acceptable.
- (+) [REDACTED] has a comprehensive privacy policy, which can be accessed here: [REDACTED]
- (+) As part of TEAM Access, [REDACTED] be able to integrate [REDACTED] with our SSO.
- (+) Based on how we decide to use [REDACTED] we may elect to forward logs to our internal log aggregation tool. It appears that we can buy a “log drain” for \$60/project.
  
- (-) At the time of this risk assessment, we have not had the opportunity to review [REDACTED] SOC2, Type II report.
- (-) [REDACTED] will not complete our custom security questionnaire unless we subscribe to the ENTERPRISE plan.
- (-) Usage of [REDACTED] will vary and without knowing the exact way that [REDACTED] will be used, there are elements of this risk picture that are unknown at this time. Business Solutions will have to disclose its specific plans to use [REDACTED] once they are known.
- (-) [REDACTED] not be signing a negotiable agreement with [REDACTED] but rather, just accepting standard terms and conditions. There may be terms that [REDACTED] would not typically agree to.
- (-) [REDACTED] not have a dedicated point of contact at [REDACTED] so if any issues arise, we will have to use automated support and communication methods. Depending on what we use [REDACTED] for, this could limit our ability to get support that we need.

None of the above constitute a recommendation to not move forward with [REDACTED] Rather, it is to inform you of certain risks so you can decide how to best move forward with [REDACTED] I am happy to elaborate on any of these if you wish, just let me know.

Thank you,  
Brian

# What could good look like?

1. Know what you're buying and have a standard approach to evaluating the risk of that vendor/service/application.
2. Does the vendor have a security team? Who are they, how would you contact them, and how quickly can you expect to hear back from them?
3. Examine documentation that matters: SOC2 reports, ISO certification(s), pen test reports, SBOM, remediation SLAs or responsible disclosure policies.
4. Evaluate their online presence (OSINT, baby).
5. Allow risk to sit with the business owner.
6. Leverage trusted communities for third-party risk assessments.

# What do parents look for when they evaluate child care options?

- They look to friends or family (people we trust) for recommendations.
- They get references.
- They perform a walkthrough to evaluate security measures.
- They check employee certifications, qualifications, and experience.
- They ask questions.
- They rely on “vibes”.

# Trusted Communities

- ISACs
- Closed, invite-only security communities
- Portfolio companies
- Friends, colleagues, peers

1. Origins of TPRM
2. Current methods of TPRM
3. Next generation TPRM
4. Summary and Call to Action



Third-Party Risk Management is about  
*reasonable assurance* - not perfection.

*Transparency* is the present and  
future of TPRM.

Over-engineered approaches to TPRM *steal resources from other security domains* and don't make anything more secure.

Independent third-party audits, certifications, and industry standards *should be preferred* over custom questionnaires.

It's not about security. It's about *trust*.

We can do this, we just have to  
*want* to do it.

# Thank you!

## Acknowledgements:

- RVAsec organizers & volunteers
- Chris Castaldo
- My colleagues @ EAB

[brian.w.markham@gmail.com](mailto:brian.w.markham@gmail.com) // @maru37 // [www.linkedin.com/in/brianwmarkham](http://www.linkedin.com/in/brianwmarkham)